CSTBS v5.2

Simplified Administrator Login - Release Change Report

Purpose

Replace the complicated administrator registration form with an existing-admin login using an automatically issued, 20-minute, single-use key. The operator never edits Python, SQLite, Notepad or an environment file to enter an administrator key.

Changes at a glance

Area	Version 5.1	Version 5.2
Admin access	Admin registration form	Email + one-time login key
Key lifetime	60 minutes	20 minutes, one use
First admin	Website registration	Terminal setup prompt, auto-created
Key storage	Hashed invitation	Hashed, bound to admin user ID
Recovery	Reset-bootstrap command	admin-key EMAIL from PowerShell
Local secret	.env setup	Auto-generated private local secret
Student accounts	Student ID + password	Unchanged
Seat bookings	Free, conflict-protected	Unchanged; CNY 0.00

User experience

• **Students:** Register with Student ID and sign in with email/password; browse and reserve seats for free.

• **Administrators:** Open /admin/login, enter the approved administrator email and key copied from the PowerShell terminal.

• **After login:** Redirect to /admin/. Token expiry does not log out an active session.

Setup and security

Windows development, database compatibility and verification

Windows PowerShell - first launch

python -m venv .venv

.\.venv\Scripts\Activate.ps1

python -m pip install -r requirements.txt

python -m flask --app run.py init-db

python -m flask --app run.py seed-events

python run.py

The server prompts for the first administrator email/name only if no administrator exists. It immediately generates and displays a 20-minute key. Visit **http://127.0.0.1:5000/admin/login** and enter the same email and key.

Lost or expired key

python -m flask --app run.py admin-key admin@university.edu

Run this in another PowerShell in the project directory, with the virtual environment activated. The new key invalidates any older unused key for that administrator. If first-run setup was skipped, run **python -m flask --app run.py admin-setup**. No key needs to be entered into Notepad or source files.

Security controls

• Keys use cryptographic randomness, HMAC-SHA256 fingerprints, exact account binding, 20-minute expiration and atomic consumption.

• No public administrator registration or automatic privilege escalation; an administrator can issue a key only to an approved admin account.

• Flask-WTF CSRF checks, Flask-Limiter request limits, Flask-Login sessions and role authorization remain active.

• Local development can securely create instance/.local_secret_key on first run; production must supply a private SECRET_KEY and HTTPS configuration.

Upgrading an existing V5.1 database

Stop the old server and back up the SQLite database and secret first. Preserve the original app secret if already configured. Run **flask init-db** in V5.2: it adds the target_user_id field and index and revokes old untargeted registration keys. It preserves existing administrators, students, seat inventory, bookings, event management and reports.

Validation and limitations

Static validation covers Python parsing/compilation, Jinja2 templates, JavaScript syntax and archive integrity. Full Flask route and SMTP integration tests require installing dependencies on Windows and running **python -m unittest discover -s tests -v**. The local operator workflow is suitable for development; university SSO with MFA is recommended for public production deployment.

GitHub tag: v5.2 **Release title:** CSTBS v5.2 - Simplified Administrator Login